

SIMATS ENGINEERING
ASSESSMENT TOOL 02

COURSE NAME:
ITA1405

Ethical Hacking COURSE CODE:

COURSE OUTCOME COVERED

CO4: Implement network security testing methods by performing web server attacks, analyzing web application vulnerabilities, and assessing wireless network security using Kali Linux.

QUESTIONS: 01
Marks:100

Total

Annexure A

VULNERABILITY ASSESSMENT REPORT

Code of Conduct:

I K. Nithin Varma / 192312272 (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.

I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student: K. Nithin Varma

1. TJX Companies Wireless Network Breach, 2005–2007

TJX Companies experienced a major payment-card data breach after attackers obtained unauthorized wireless access to its retail network. Investigations found that TJX had used WEP while transitioning to WPA and had not implemented adequate controls to restrict wireless access. The incident demonstrated the risks of obsolete encryption, inadequate monitoring, weak network segmentation, and insecure transmission of sensitive data.

Assignment Question: Prepare a Vulnerability Assessment Report examining the wireless encryption, authentication, network segmentation, monitoring, and payment-data protection weaknesses that contributed to the TJX incident. Recommend how WPA2/WPA3, enterprise authentication, rogue-access-point detection, and PCI DSS controls could have reduced the risk.

ANSWER:

1. Introduction

TJX Companies suffered a major network intrusion in which attackers gained access through poorly protected wireless networks and subsequently accessed systems containing customer and payment-related information. The investigation found that TJX was using **Wired Equivalent Privacy (WEP)** while transitioning to stronger WPA protection. The investigation also identified weaknesses in monitoring, network segregation, and data retention.

2. Objective

The objective of this vulnerability assessment is to examine the weaknesses in:

- Wireless encryption
- Authentication
- Network segmentation
- Security monitoring
- Payment-data protection

and recommend security controls that could have reduced the risk and impact of the TJX breach.

3. Major Vulnerabilities Identified

Vulnerability	Severity	Impact
Use of WEP encryption	Critical	Wireless network could be compromised
Weak wireless access controls	High	Unauthorized network access
Insufficient network segmentation	Critical	Attackers could reach sensitive systems
Inadequate security monitoring	High	Intrusion remained undetected
Excessive payment/personal data retention	High	Increased impact of the breach
Delayed migration to stronger encryption	High	Prolonged exposure to wireless attacks

4. Wireless Encryption Weakness

TJX used **WEP**, an obsolete wireless security protocol. WEP had well-known cryptographic weaknesses and was not adequate for protecting sensitive networks. The investigation concluded that WEP could be defeated relatively easily and that the wireless weakness may have contributed to access to TJX systems.

TJX began its WPA conversion in October 2005, but the conversion was not completed until January 2007. This left a significant period during which the weaker protection remained in use.

Recommendation

- Completely eliminate WEP.
- Use **WPA2-AES** or preferably **WPA3** where supported.
- Avoid outdated encryption such as WEP and weak legacy configurations.
- Regularly review wireless security configurations.

5. Authentication Weakness

Wireless access should use strong authentication rather than relying on shared or weak credentials.

Recommended solution

Use **WPA2/WPA3-Enterprise with IEEE 802.1X and EAP**, supported by a centralized authentication server such as RADIUS.

Enterprise authentication provides individual credentials and stronger control over who can access the wireless network. PCI wireless guidance describes WPA2 Enterprise as using IEEE 802.1X/EAP with AES encryption.

Benefits

- Individual user authentication
- Easier account revocation
- Better access control
- Reduced risk from shared passwords
- Improved logging and accountability

6. Network Segmentation Weakness

A major concern was the lack of sufficient separation between wireless networks and systems containing sensitive information. The investigation specifically noted that cardholder data should have been segregated onto more secure systems while wireless security was being upgraded.

Recommendation

The network should be divided into separate security zones:

Wireless Users

|

v

Wireless Network

|

Firewall

|

v

Corporate Network

|

Firewall

|

v

Cardholder Data Environment

Wireless users should not have direct access to payment-card systems.

Firewalls and access-control rules should allow only required traffic between network segments. PCI wireless guidance specifically recommends firewalls between wireless networks and the cardholder-data environment.

7. Monitoring Weakness

TJX did not detect the intrusion quickly enough. The investigation found that attackers were able to continue accessing information for approximately a year and a half before the intrusion was discovered.

Recommendation

Organizations should implement:

- Wireless Intrusion Detection/Prevention Systems (WIDS/WIPS)
- SIEM monitoring
- Centralized security logs
- Intrusion detection
- Continuous network monitoring
- Alerts for unusual wireless activity
- Regular security assessments

Rogue-access-point detection should also be used to identify unauthorized wireless devices.

8. Payment-Data Protection Weakness

TJX retained significant amounts of sensitive information, including payment-card information and other personal identification information. The investigation concluded that excessive collection and long retention increased the potential impact of the breach.

Recommendation

- Store only necessary payment information.
- Apply data-retention policies.
- Secure stored cardholder data using strong controls.
- Encrypt sensitive data where appropriate.
- Tokenize payment information where possible.
- Secure transmission of cardholder data.
- Delete data when it is no longer required.

PCI DSS provides baseline technical and operational requirements for protecting payment-account data.

9. PCI DSS Controls

The following PCI DSS controls could have reduced the risk:

Requirement 1 – Network Security

Use firewalls and network segmentation to separate wireless networks from the cardholder-data environment.

Requirement 2 – Secure Configuration

Change default passwords, wireless keys, and device configurations.

Requirement 4 – Protect Data in Transit

Use strong cryptography and secure protocols when transmitting cardholder data over open or public networks.

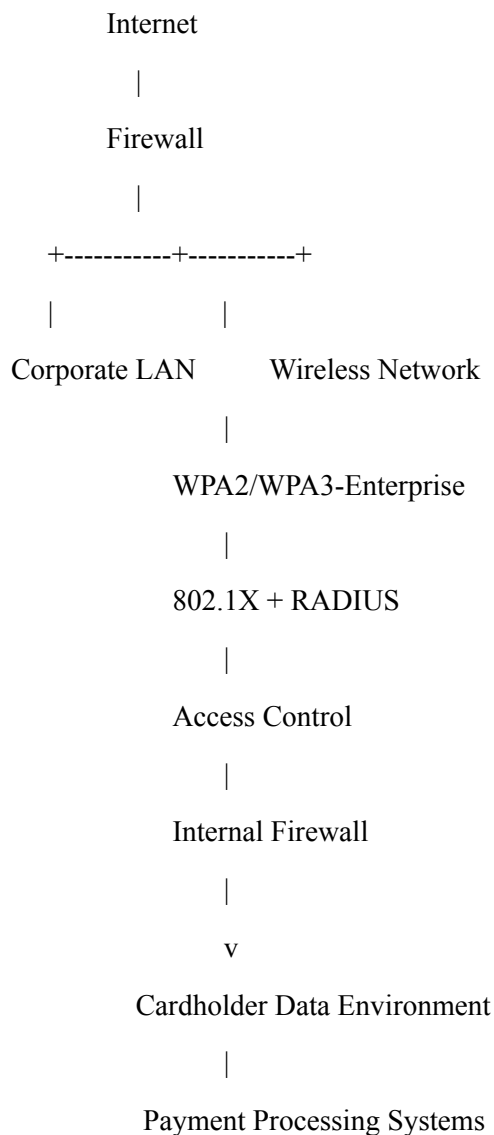
Requirement 10 – Logging and Monitoring

Monitor network and system activity and investigate suspicious events.

Requirement 11 – Testing

Regularly test wireless and network security controls and identify unauthorized wireless access points.

10. Recommended Security Architecture



This architecture limits direct access from wireless users to sensitive payment systems.

11. Risk Classification

Weakness	Severity	Recommended Control
WEP encryption	Critical	WPA2-AES / WPA3
Weak wireless authentication	High	WPA2/WPA3-Enterprise + 802.1X
Poor network segmentation	Critical	Firewalls and VLAN/network segmentation
Inadequate monitoring	High	WIDS/WIPS, SIEM and continuous monitoring
Excessive data retention	High	Data minimization and retention policies
Delayed security upgrades	High	Regular risk assessment and patch management

12. Overall Recommendations

1. Replace obsolete WEP with WPA2-AES or WPA3.
2. Use WPA2/WPA3-Enterprise with 802.1X and RADIUS.
3. Deploy rogue-access-point detection.
4. Separate wireless networks from the cardholder-data environment.
5. Use firewalls and strict access-control rules between network zones.
6. Implement continuous security monitoring and centralized logging.
7. Minimize collection and retention of payment and personal information.
8. Encrypt and protect sensitive data.
9. Perform regular vulnerability assessments and wireless security testing.
10. Maintain compliance with applicable PCI DSS requirements.

13. Conclusion

The TJX incident demonstrates that strong security requires **multiple layers of protection**. The use of weak WEP encryption, insufficient network segregation, inadequate monitoring, delayed security improvements, and excessive retention of sensitive information increased the likelihood and impact of the breach. The investigation also emphasized the importance of layered safeguards such as network segregation and active monitoring.

Using WPA2/WPA3-Enterprise, 802.1X authentication, rogue-access-point detection, network segmentation, continuous monitoring, data minimization, and PCI DSS controls would have significantly reduced the risk of unauthorized wireless access and limited the attacker's ability to reach sensitive payment systems.

References

- Office of the Privacy Commissioner of Canada – TJX Investigation.
- Office of the Privacy Commissioner of Canada – TJX Case Summary.
- PCI Security Standards Council – PCI DSS Wireless Guidelines.

- PCI Security Standards Council – PCI DSS.

2. Lowe's Wireless Network Intrusion, 2003

In 2003, attackers compromised the wireless network of a Lowe's retail store in Southfield, Michigan. The compromised wireless connection provided access to the company's central systems and other retail locations. The attackers attempted to install software intended to capture customers' credit-card information.

Assignment Question: Prepare a Vulnerability Assessment Report identifying the weaknesses that allowed a local wireless compromise to create access to a nationwide corporate network. Assess authentication, wireless isolation, firewall controls, point-of-sale segmentation, intrusion detection, and centralized access management.

ANSWER:

1. Introduction

In 2003, attackers compromised the wireless network of a Lowe's retail store in Southfield, Michigan. The incident demonstrated how inadequate wireless security and poor network isolation can allow a compromise at a single retail location to create access to broader corporate systems. The attackers attempted to install software designed to capture customers' credit-card information.

2. Objective

The objective of this vulnerability assessment is to identify the weaknesses that allowed a local wireless compromise to potentially reach the wider corporate network and assess:

- Wireless authentication
- Wireless network isolation
- Firewall controls
- Point-of-sale (POS) segmentation
- Intrusion detection
- Centralized access management

3. Vulnerability Assessment

Vulnerability	Severity	Impact
Weak wireless authentication	High	Unauthorized users could access the network
Insufficient wireless isolation	Critical	Wireless compromise could reach internal systems
Weak firewall controls	Critical	Unnecessary traffic could move between networks

Poor POS segmentation	Critical	Payment systems were exposed to network compromise
Insufficient intrusion detection	High	Suspicious activity could remain undetected
Weak centralized access management	High	Difficult to control and monitor access across locations

4. Wireless Authentication Weakness

The wireless network was not sufficiently protected against unauthorized access. A compromised wireless connection provided a path into internal systems.

Recommendation

Use:

- WPA2/WPA3-Enterprise
- IEEE 802.1X
- RADIUS authentication
- Individual user/device credentials
- Strong authentication policies

Shared wireless passwords should be avoided for sensitive corporate networks.

5. Wireless Network Isolation

A major weakness was that wireless access was not sufficiently isolated from internal corporate systems.

A secure design should be:

Wireless Network

|
v

Firewall

|
v

Isolated VLAN

|
v

Limited Corporate Services

Wireless users should not receive unrestricted access to internal servers.

Recommendation

Use VLANs, firewalls, ACLs, and network access control to restrict wireless traffic.

6. Firewall Control Weakness

Firewalls should control communication between wireless, corporate, and payment networks.

If wireless devices can directly communicate with internal systems, a compromise can become a larger corporate security incident.

Recommendation

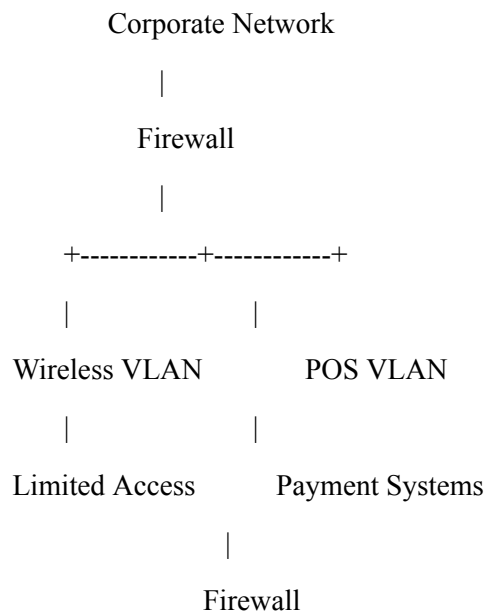
Implement:

- Stateful firewalls
- Network ACLs
- Default-deny rules
- Only required ports and protocols
- Logging of denied and suspicious traffic

7. Point-of-Sale Segmentation

POS systems contain highly sensitive payment information and should be isolated from general-purpose networks.

Recommended architecture:



Wireless devices should never have direct access to POS systems.

Impact

Without proper segmentation, attackers who compromise a wireless network may attempt to reach payment systems and install malicious software.

8. Intrusion Detection Weakness

Intrusion detection is important for identifying unusual wireless and internal network activity.

Recommended controls

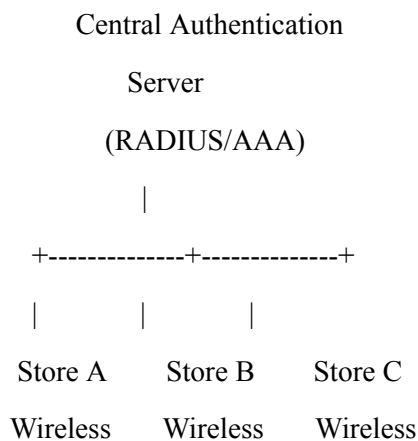
- Wireless Intrusion Detection System (WIDS)
- Wireless Intrusion Prevention System (WIPS)
- Network IDS/IPS
- Centralized logging
- Security alerts
- Continuous monitoring

These controls can identify rogue access points, unusual traffic, unauthorized devices, and suspicious connections.

9. Centralized Access Management

A nationwide organization should centrally manage wireless and network access.

Recommended solution



Centralized access management provides:

- Consistent security policies
- Centralized authentication
- User/device management
- Immediate account revocation
- Centralized logging
- Better visibility across locations

10. Risk Classification

Area	Risk	Recommended Control
Authentication	High	WPA2/WPA3-Enterprise + 802.1X
Wireless isolation	Critical	VLANs + firewall
Firewall	Critical	Default-deny ACLs

POS security	Critical	Dedicated POS network
Monitoring	High	IDS/IPS + WIDS/WIPS
Access management	High	Centralized AAA/RADIUS

11. Remediation Measures

1. Replace weak wireless security with WPA2/WPA3-Enterprise.
2. Implement 802.1X and centralized RADIUS authentication.
3. Separate wireless users from corporate and POS networks.
4. Use firewalls between security zones.
5. Apply least-privilege network access.
6. Deploy wireless and network intrusion detection.
7. Centrally manage user and device authentication.
8. Monitor network traffic and security logs continuously.
9. Regularly audit wireless access points and network configurations.
10. Protect POS systems using dedicated segmentation and strict access controls.

12. Conclusion

The Lowe's incident demonstrates that a local wireless compromise can become a major corporate security problem when wireless networks are not properly isolated from internal systems. Weak authentication, insufficient firewall restrictions, inadequate POS segmentation, limited intrusion detection, and decentralized access management can allow attackers to move from a local wireless network toward sensitive corporate resources.

Implementing WPA2/WPA3-Enterprise, 802.1X/RADIUS, strong firewall controls, VLAN-based segmentation, dedicated POS networks, WIDS/WIPS, IDS/IPS, and centralized access management would significantly reduce the likelihood and impact of such an attack.

3. Firesheep and Public Wi-Fi Session Hijacking, 2010

The Firesheep browser extension demonstrated how attackers connected to the same open wireless network could capture unencrypted session cookies and impersonate authenticated users. The event highlighted the danger of websites encrypting only the login page while transmitting later session information without full HTTPS protection.

Assignment Question: Prepare a Vulnerability Assessment Report for a public Wi-Fi provider affected by Firesheep-style session hijacking. Assess open-network authentication, session-cookie protection, HTTPS enforcement, HSTS, VPN use, wireless client isolation, and user-security awareness.

ANSWER:

1. Introduction

In 2010, the Firesheep browser extension demonstrated the risks of using web applications over open public Wi-Fi networks. Attackers connected to the same wireless network could capture unencrypted session cookies and potentially impersonate authenticated users.

The incident highlighted that protecting only the login page with HTTPS was insufficient. **The entire authenticated session should use HTTPS.**

2. Objective

The objective is to assess a public Wi-Fi environment against Firesheep-style session hijacking and examine:

- Open-network authentication
- Session-cookie protection
- HTTPS enforcement
- HSTS
- VPN usage
- Wireless client isolation
- User security awareness

3. Vulnerability Assessment

Vulnerability	Severity	Impact
Open/unsecured Wi-Fi	High	Network traffic may be exposed
HTTP session traffic	Critical	Session cookies may be intercepted
Insecure cookies	High	Session theft may be possible
No HTTPS enforcement	Critical	Sensitive traffic can be exposed
Missing HSTS	Medium/High	Downgrade attacks may be possible
No client isolation	High	Users can directly interact on the wireless network
Lack of VPN guidance	Medium	Users have reduced protection on untrusted networks
Poor security awareness	Medium	Users may connect or browse insecurely

4. Open-Network Authentication

Public Wi-Fi networks that provide completely open connectivity allow nearby users to communicate over the same wireless environment.

Recommendation

The provider should use appropriate wireless security and network controls. For public guest networks, where an open network is necessary, additional protections such as:

- Captive portal authentication

- Client isolation
- Network segmentation
- Secure DNS
- Rate limiting

should be implemented.

Authentication to the Wi-Fi network alone does **not** replace HTTPS protection for web applications.

5. Session-Cookie Protection

Session cookies are used to maintain authenticated sessions.

If cookies are transmitted over HTTP, an attacker on the same network may potentially capture them.

Secure cookie attributes

Cookies should use:

Secure

HttpOnly

SameSite

Impact

A stolen session cookie may allow an attacker to impersonate the authenticated user without knowing the user's password.

Recommendation

Use secure cookies and transmit authenticated sessions exclusively over HTTPS.

6. HTTPS Enforcement

A major weakness demonstrated by Firesheep was protecting only the login page while allowing subsequent authenticated requests over HTTP.

Test

```
curl -I http://<TARGET_URL>
```

A secure application should redirect HTTP requests to HTTPS.

Example:

```
HTTP/1.1 301 Moved Permanently
```

```
Location: https://<TARGET_URL>
```

Recommendation

Use HTTPS for:

- Login
- Authentication
- Session management

- Account pages
- Payment pages
- All other authenticated requests

7. HSTS

HTTP Strict Transport Security (HSTS) tells browsers to communicate with a website using HTTPS.

Example:

Strict-Transport-Security: max-age=31536000; includeSubDomains

Impact of Missing HSTS

Without HSTS, users may initially access a site over HTTP, increasing exposure to downgrade or insecure-connection attacks.

Recommendation

Enable HSTS after ensuring the entire application and its subdomains are correctly configured for HTTPS.

8. VPN Usage

A VPN can provide an additional encrypted tunnel between the user's device and the VPN service, particularly when using an untrusted public network.

Recommendation

Public Wi-Fi providers should educate users that:

- HTTPS is essential.
- A trusted VPN can provide additional protection.
- Users should avoid sensitive activities on suspicious networks.
- VPNs should be obtained from reputable providers.

A VPN should be considered an additional security layer, not a replacement for HTTPS.

9. Wireless Client Isolation

Client isolation prevents wireless users from directly communicating with other clients on the same Wi-Fi network.

Recommended design

Internet

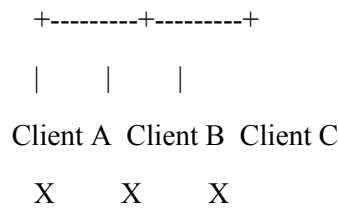
|

Firewall

|

Guest Wi-Fi

|



No direct client-to-client communication

Impact

Client isolation reduces the ability of one wireless user to directly interact with other users' devices.

10. User Security Awareness

Users should be educated about the risks of public Wi-Fi.

Recommended awareness practices

- Check that websites use HTTPS.
- Avoid entering sensitive information on suspicious websites.
- Use trusted VPN services when appropriate.
- Keep browsers and operating systems updated.
- Do not ignore browser certificate warnings.
- Avoid connecting to unknown or suspicious Wi-Fi networks.
- Enable multi-factor authentication where available.

11. Risk Classification

Security Area	Severity	Recommended Control
Open Wi-Fi	High	Client isolation + secure network design
HTTP sessions	Critical	Full HTTPS
Session cookies	High	Secure, HttpOnly, SameSite
Missing HSTS	Medium/High	Enable HSTS
No VPN guidance	Medium	User education/VPN guidance
No client isolation	High	Enable AP/client isolation
Poor awareness	Medium	Security awareness training

12. Remediation Plan

1. Enforce HTTPS across the entire website.
2. Redirect all HTTP traffic to HTTPS.
3. Enable HSTS.
4. Configure Secure, HttpOnly, and SameSite cookie attributes.

5. Enable wireless client isolation.
6. Use network segmentation for guest users.
7. Recommend trusted VPN usage on untrusted networks.
8. Educate users about HTTPS and public Wi-Fi risks.
9. Implement multi-factor authentication where possible.
10. Monitor the wireless network for suspicious activity.

13. Conclusion

The Firesheep incident demonstrated that securing only the login page is not enough. If authenticated sessions continue over unencrypted HTTP, session cookies may be exposed to attackers on the same network.

A secure public Wi-Fi environment should combine full HTTPS enforcement, HSTS, secure session cookies, wireless client isolation, network segmentation, optional VPN protection, and user-security awareness. These controls work together to significantly reduce the risk of session hijacking on public wireless networks.

4. DarkHotel Attacks Through Hotel Wi-Fi Networks

The DarkHotel campaign targeted business executives and government officials using compromised hotel networks. Selected guests connecting to hotel Wi-Fi were presented with fraudulent software-update prompts that delivered malware. The campaign demonstrated the risks associated with third-party Wi-Fi management, captive portals, insecure update mechanisms, and insufficient guest-network monitoring.

Assignment Question: Prepare a Vulnerability Assessment Report for the affected hotel environment. Examine guest authentication, captive-portal security, DNS integrity, network segmentation, third-party access, digital-signature verification, malware detection, and monitoring of privileged hotel-network systems.

ANSWER:

1. Introduction

The DarkHotel campaign demonstrated the risks associated with compromised hotel networks. Attackers targeted selected hotel guests, particularly high-value individuals, and used fraudulent software-update prompts to deliver malware. The incident highlights the importance of securing hotel Wi-Fi, captive portals, DNS, third-party systems, software updates, and network monitoring.

2. Objective

The objective of this assessment is to identify weaknesses in:

- Guest authentication
- Captive-portal security
- DNS integrity

- Network segmentation
- Third-party access
- Software-update verification
- Malware detection
- Privileged-system monitoring

3. Vulnerability Assessment

Vulnerability	Severity	Impact
Weak guest authentication	High	Unauthorized network access
Insecure captive portal	High	Credential theft or manipulation
DNS manipulation	Critical	Users may be redirected to malicious sites
Poor network segmentation	Critical	Attackers may reach internal systems
Excessive third-party access	High	Compromise of trusted services
Weak software-update validation	Critical	Malware can be installed through fake updates
Insufficient malware detection	High	Malicious software may remain undetected
Poor privileged-system monitoring	High	Attacks against critical systems may go unnoticed

4. Guest Authentication

Hotel Wi-Fi should authenticate guests securely and prevent unauthorized access.

Recommendation

- Use secure authentication mechanisms.
- Avoid shared administrator credentials.
- Use unique guest access credentials where appropriate.
- Apply rate limiting and account controls.
- Expire temporary guest credentials automatically.

Authentication should be separated from hotel administrative systems.

5. Captive Portal Security

Captive portals should use HTTPS and protect user credentials.

Possible weaknesses

- HTTP login forms
- Weak authentication

- Poor session management
- Untrusted redirects
- Lack of certificate validation

Recommendation

Use:

HTTPS

Secure cookies

HttpOnly cookies

Strong session management

Users should not be redirected to unknown domains or asked to install suspicious software.

6. DNS Integrity

DNS manipulation can redirect users from legitimate websites to malicious destinations.

Recommendation

- Use trusted DNS resolvers.
- Protect DNS infrastructure.
- Monitor unexpected DNS changes.
- Use DNS security monitoring.
- Consider DNSSEC where appropriate.
- Prevent unauthorized modification of DNS configurations.

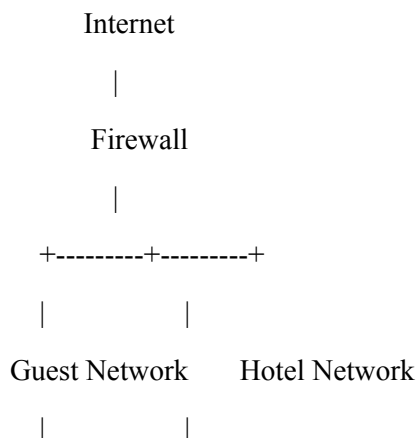
Impact

Compromised DNS can redirect hotel guests to phishing pages or malicious update sites.

7. Network Segmentation

Hotel guest networks should be completely separated from internal hotel systems.

Recommended design:



Guest Devices Admin Systems

|

POS / Servers

Guest devices should not directly access:

- Hotel management systems
- POS systems
- Employee devices
- Server networks
- Network administration interfaces

8. Third-Party Access

Hotels commonly depend on third-party providers for Wi-Fi, payment, booking, and network management.

Risks

Poorly controlled third-party access can create another path into the hotel network.

Recommendation

- Apply least privilege.
- Use individual accounts.
- Use MFA.
- Review vendor access regularly.
- Disable unused accounts.
- Monitor third-party connections.
- Require security standards in vendor agreements.

9. Software-Update Verification

A key risk demonstrated by DarkHotel-style attacks is the use of fraudulent software-update prompts.

Users should never trust an update merely because it appears while connected to a hotel network.

Recommendation

Software updates should:

- Come from trusted vendors.
- Use HTTPS.
- Use cryptographic signatures.
- Be verified before installation.
- Be distributed through trusted update mechanisms.

Digital signatures help verify that software has not been modified and originates from the expected publisher.

10. Malware Detection

Hotel networks should use multiple layers of malware protection.

Recommended controls

- Endpoint Detection and Response (EDR)
- Antivirus/anti-malware
- Network IDS/IPS
- Email/web filtering
- Application allowlisting where appropriate
- Security monitoring

Suspicious downloads, executable files, and unusual network behavior should generate alerts.

11. Privileged-System Monitoring

Administrative hotel systems are high-value targets.

Recommendation

Monitor:

- Administrator logins
- Configuration changes
- Network-device changes
- Firewall changes
- DNS changes
- New privileged accounts
- Failed authentication attempts
- Unusual remote access

Use centralized logging and SIEM to detect suspicious activity.

12. Risk Classification

Area	Severity	Recommended Control
Guest authentication	High	Strong authentication
Captive portal	High	HTTPS + secure sessions
DNS integrity	Critical	Protected DNS + monitoring
Network segmentation	Critical	VLANs + firewalls

Third-party access	High	MFA + least privilege
Software updates	Critical	Digital signatures
Malware detection	High	EDR + IDS/IPS
Privileged monitoring	High	SIEM + centralized logging

13. Remediation Measures

1. Secure guest authentication.
2. Use HTTPS for captive portals.
3. Protect DNS infrastructure and monitor DNS changes.
4. Completely isolate guest Wi-Fi from hotel internal networks.
5. Apply MFA and least privilege to third-party accounts.
6. Verify software updates using digital signatures.
7. Deploy endpoint and network malware detection.
8. Monitor privileged hotel-network systems continuously.
9. Maintain centralized security logs.
10. Conduct regular security assessments and vendor security reviews.

14. Conclusion

The DarkHotel campaign demonstrates that hotel Wi-Fi can become a serious security risk when attackers compromise network infrastructure or trusted communication channels. Weak captive portals, DNS manipulation, poor network segmentation, excessive third-party privileges, and unverified software updates can allow attackers to target high-value users.

A strong security architecture should combine secure guest authentication, HTTPS-protected captive portals, DNS integrity, strict network segmentation, controlled third-party access, digitally signed software updates, malware detection, and continuous monitoring of privileged systems. These controls can significantly reduce the likelihood and impact of DarkHotel-style attacks.

5. Marriott Wi-Fi Deauthentication Incident, 2014

The United States Federal Communications Commission investigated Marriott after equipment was used to send Wi-Fi deauthentication messages that prevented guests from using their personal hotspots. Marriott agreed to pay a civil penalty of \$600,000. The incident showed how unprotected wireless management frames could be misused to disconnect legitimate users.

Assignment Question: Prepare a Vulnerability Assessment Report analysing the misuse of IEEE 802.11 deauthentication frames. Discuss availability risks, wireless interference, Protected Management Frames, WPA3 requirements, wireless intrusion detection,

acceptable-use policies, and legal consequences.

1. Introduction

In 2014, the U.S. Federal Communications Commission (FCC) investigated Marriott after Wi-Fi equipment was used to transmit deauthentication messages that disrupted guests' personal Wi-Fi hotspots. Marriott agreed to pay a **\$600,000 civil penalty**. The incident demonstrated the availability risks associated with misuse of IEEE 802.11 management frames.

2. Objective

The objective of this assessment is to analyze:

- IEEE 802.11 deauthentication frames
- Wireless availability risks
- Wireless interference
- Protected Management Frames (PMF)
- WPA3 security
- Wireless intrusion detection
- Acceptable-use policies
- Legal and regulatory consequences

3. Deauthentication Frame Vulnerability

IEEE 802.11 deauthentication frames are used to terminate a wireless connection.

In older wireless configurations, management frames were not always cryptographically protected. An attacker or improperly configured equipment could therefore transmit forged deauthentication frames and cause legitimate clients to disconnect.

Impact

- Users can lose network connectivity.
- Wireless services can become unavailable.
- Repeated disconnections can cause denial-of-service conditions.
- Business operations may be disrupted.

Severity: High – Availability

4. Wireless Interference

Wireless networks operate in shared radio-frequency environments. Intentional or excessive interference can prevent legitimate devices from communicating properly.

Possible effects include:

- Connection failures
- Reduced network performance
- Repeated disconnections

- Denial of service

Recommendation

Organizations should monitor wireless environments and investigate unusual interference rather than intentionally disrupting legitimate devices.

5. Protected Management Frames (PMF)

Protected Management Frames (PMF) provide cryptographic protection for certain wireless management frames, including deauthentication and disassociation frames.

PMF helps prevent attackers from simply forging these frames to disconnect users.

Recommendation

Enable PMF where supported:

PMF / 802.11w



Protect management frames



Reduce forged deauthentication attacks

6. WPA3 Requirements

WPA3 provides improved wireless security compared with older wireless standards and supports stronger protection mechanisms.

WPA3 networks support **Protected Management Frames**, helping protect management traffic from spoofing and misuse.

Recommendation

- Use WPA3 where supported.
- Enable PMF.
- Upgrade legacy wireless equipment.
- Avoid obsolete wireless security configurations.
- Maintain secure enterprise authentication for corporate networks.

7. Wireless Intrusion Detection

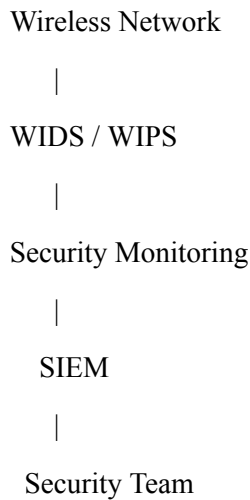
Organizations should deploy **Wireless Intrusion Detection Systems (WIDS)** and, where appropriate, **Wireless Intrusion Prevention Systems (WIPS)**.

These systems can help detect:

- Excessive deauthentication frames
- Rogue access points
- Unauthorized wireless devices
- Suspicious management-frame activity

- Unusual interference

Example Architecture



8. Acceptable-Use Policies

Organizations should establish clear wireless acceptable-use policies.

The policy should specify:

- Authorized wireless equipment
- Prohibited interference
- Approved network-management practices
- Guest-network rules
- Employee responsibilities
- Incident-reporting procedures
- Consequences for misuse

Network administrators should not use security equipment to intentionally disrupt legitimate users or competing networks without appropriate legal authorization.

9. Legal Consequences

The Marriott case demonstrates that misuse of wireless equipment can result in regulatory enforcement and financial penalties.

The FCC investigated Marriott's use of deauthentication-related technology and Marriott agreed to pay a **\$600,000 civil penalty**.

Security Lesson

Wireless security controls must be used for legitimate security purposes. Organizations should consider applicable telecommunications, spectrum, consumer-protection, and other laws before deploying wireless interference or blocking technologies.

10. Risk Classification

Finding	Severity	Impact	Recommended Control
Unprotected management frames	High	Client disconnection	Enable PMF
Deauthentication misuse	High	Denial of service	PMF + WIDS/WIPS
Wireless interference	High	Network availability loss	RF monitoring
Lack of wireless monitoring	High	Attacks may remain undetected	WIDS/WIPS
Weak wireless configuration	High	Increased attack surface	WPA3
Poor acceptable-use policy	Medium	Misuse and compliance risk	Clear policies
Unauthorized interference	High	Legal/regulatory consequences	Compliance controls

11. Remediation Measures

1. Deploy WPA3 where supported.
2. Enable Protected Management Frames (PMF).
3. Upgrade legacy wireless infrastructure.
4. Deploy WIDS/WIPS for wireless monitoring.
5. Monitor unusual deauthentication activity.
6. Monitor radio-frequency interference.
7. Separate guest and corporate wireless networks.
8. Create clear wireless acceptable-use policies.
9. Train network administrators on authorized wireless-security practices.
10. Review legal and regulatory requirements before deploying wireless-disruption controls.

12. Conclusion

The Marriott incident demonstrates that wireless management frames can create serious availability and regulatory risks when they are not properly protected or are misused. Forged or excessive deauthentication activity can disconnect legitimate wireless clients and result in denial-of-service conditions.

Using WPA3, Protected Management Frames, WIDS/WIPS, wireless monitoring, proper network policies, and administrator training can reduce the risk. The incident also highlights that wireless security controls must be deployed responsibly and in accordance with applicable laws and regulations.